Reporte GuardMyCode

Cliente: Empresa Ejemplo

Fecha: 2026-10-16 19:04 UTC

Proyectos revisados: tienda-en-linea

1. Resumen para la dirección

F

CALIFICACIÓN DE RIESGO

Datos de clientes expuestos al público

5	9	4	2
Crítica	Alta	Media	Baja

Calificación antes de correcciones. A: sin problemas serios. B: solo problemas medios. C: problemas de riesgo alto abiertos. D: problemas críticos abiertos. F: datos de clientes abiertos al público.

Problemas más urgentes:

1. **Las reglas de Firebase permiten acceso a cualquiera (if true)** (crítica, mismo día) — `firestore.rules:4`. Exigir usuario con sesión y verificar que sea dueño, por ejemplo: allow read, write: if request.auth.uid == userId;
2. **Llave de acceso de AWS** (crítica, mismo día) — `.env:1`. Primero revocar y rotar esta credencial con el proveedor; después moverla a variables de entorno o a un gestor de secretos y borrarla del historial de git.
3. **URL de base de datos con contraseña** (crítica, mismo día) — `.env:2`. Primero revocar y rotar esta credencial con el proveedor; después moverla a variables de entorno o a un gestor de secretos y borrarla del historial de git.
4. **Llave secreta de Stripe en producción** (crítica, mismo día) — `billing/stripe.js:1`. Primero revocar y rotar esta credencial con el proveedor; después moverla a variables de entorno o a un gestor de secretos y borrarla del historial de git.
5. **Llave service_role de Supabase (acceso total a la base de datos)** (crítica, mismo día) — `src/lib/supabase.ts:1`. Primero revocar y rotar esta credencial con el proveedor; después moverla a variables de entorno o a un gestor de secretos y borrarla del historial de git.

+9 hallazgos más en la tabla de abajo

2. Inventario

Proyecto	Archivos	Lenguajes	Herramientas y plataformas de IA detectadas	Personas que hicieron cambios	Commits	Último cambio	Commits marcados como escritos con IA	Dónde está alojado el código
tienda-en-linea	10	Python, JavaScript, TypeScript, SQL	Claude Code, Supabase, Firebase	1	3	2026-10-16	Claude 1	—

3. Hallazgos

#	Severidad	Área	Problema	Ubicación	Evidencia (enmascarada)	Cómo corregir
1	**Crítica**	Exposición externa	Las reglas de Firebase permiten acceso a cualquiera (if true) Cualquier persona en internet puede leer o cambiar estos datos sin iniciar sesión.	firestore.rules:4	—	Exigir usuario con sesión y verificar que sea dueño, por ejemplo: allow read, write: if request.auth.uid == userId;
2	**Crítica**	Secretos	Llave de acceso de AWS Encontrado en el código.	.env:1	AK…****** (20 caracteres)	Primero revocar y rotar esta credencial con el proveedor; después moverla a variables de entorno o a un gestor de secretos y borrarla del historial de git.
3	**Crítica**	Secretos	URL de base de datos con contraseña Encontrado en el código.	.env:2	****** (10 caracteres)	Primero revocar y rotar esta credencial con el proveedor; después moverla a variables de entorno o a un gestor de secretos y borrarla del historial de git.
4	**Crítica**	Secretos	Llave secreta de Stripe en producción Encontrado en el código.	billing/stripe.js:1	sk_l…******…mJ (32 caracteres)	Primero revocar y rotar esta credencial con el proveedor; después moverla a variables de entorno o a un gestor de secretos y borrarla del historial de git.
5	**Crítica**	Secretos	Llave service_role de Supabase (acceso total a la base de datos) Encontrado en el código.	src/lib/supabase.ts:1	eyJh…******…r3 (136 caracteres)	Primero revocar y rotar esta credencial con el proveedor; después moverla a variables de entorno o a un gestor de secretos y borrarla del historial de git.
6	**Alta**	Configuración de IA	Claude Code configurado para no pedir ningún permiso El agente de IA puede ejecutar cualquier comando, editar cualquier archivo y usar la red sin preguntar, en cualquier computadora que abra este proyecto.	.claude/settings.json	—	Quitar defaultMode bypassPermissions y permitir solo los comandos específicos que el proyecto necesita.
7	**Alta**	Configuración de IA	Caracteres ocultos en un archivo de instrucciones para IA (3) Los caracteres invisibles en archivos que dan instrucciones a herramientas de IA pueden esconder órdenes a los revisores humanos (ataque 'rules file backdoor').	CLAUDE.md:2	U+200B, U+202C, U+202E	Revisar el archivo con un visor hexadecimal, quitar los caracteres ocultos y averiguar quién los agregó.
8	**Alta**	Fallas de código	SQL armado uniendo texto (posible inyección SQL) Si se mete texto del usuario directamente en SQL, un atacante puede leer o cambiar la base de datos.	api/app.py:3	—	Usar consultas con parámetros o el constructor de consultas del ORM.
9	**Alta**	Exposición externa	Secreto expuesto al navegador mediante NEXT_PUBLIC_SUPABASE_SERVICE_ROLE_KEY Las variables con este prefijo se incluyen en el sitio web y cualquier visitante puede verlas.	src/lib/supabase.ts:2	—	Mantener los secretos solo en el servidor; usarlos desde una ruta o función del backend.

#	Severidad	Área	Problema	Ubicación	Evidencia (enmascarada)	Cómo corregir
10	**Alta**	Exposición externa	La tabla 'customers' no tiene seguridad por fila (RLS) En Supabase, las tablas del esquema public sin seguridad por fila pueden ser leídas y editadas por cualquiera que tenga la llave anon pública, que viene dentro del sitio web. Es la falla detrás de CVE-2025-48757, que expuso datos de más de 170 apps hechas con IA.	supabase/migrations/001_init.sql:1	—	Ejecutar: alter table customers enable row level security; y agregar políticas que limiten a cada usuario a sus propios registros.
11	**Alta**	Exposición externa	Política de base de datos que permite todo (using true) Una política de seguridad por fila con 'true' deja que cualquier visitante con la llave pública lea o cambie estos registros. Los creadores de apps con IA suelen generarla para que la app 'simplemente funcione'.	supabase/migrations/001_init.sql:4	—	Limitar la política al dueño, por ejemplo using (auth.uid() = user_id), y probarla sin sesión iniciada.
12	**Alta**	Secretos	Archivo de entorno (.env) subido al repositorio Los archivos .env suelen guardar contraseñas y llaves de API. Cualquiera con acceso al repositorio, hoy o en el pasado, puede leerlos.	.env	—	Rotar cada valor, quitar el archivo del repositorio y del historial, agregar .env a .gitignore y subir un .env.example con valores vacíos.
13	**Alta**	Secretos	Llave de API de Anthropic Encontrado en el código. Es un archivo de configuración de una herramienta o agente de IA, un punto común de fuga al conectar la IA con sistemas de la empresa.	.mcp.json:10	sk-a…******…y8 (54 caracteres)	Primero revocar y rotar esta credencial con el proveedor; después moverla a variables de entorno o a un gestor de secretos y borrarla del historial de git.
14	**Alta**	Secretos	Llave de API de OpenAI Encontrado en el historial de git; borrar el archivo hoy no lo elimina.	config.py (commit de94084f)	sk-p…******…li (49 caracteres)	Primero revocar y rotar esta credencial con el proveedor; después moverla a variables de entorno o a un gestor de secretos y borrarla del historial de git.
15	**Media**	Configuración de IA	Claude Code con permiso previo para comandos de terminal amplios Permisos previos: Bash(*)	.claude/settings.json	—	Cambiar las reglas amplias por los comandos exactos necesarios, como Bash(npm test).
16	**Media**	Configuración de IA	Todos los servidores MCP del proyecto se aprueban automáticamente Cualquier servidor MCP que se agregue al repositorio se conectará al agente de IA sin revisión.	.claude/settings.json	—	Quitar enableAllProjectMcpServers y aprobar los servidores por nombre.
17	**Media**	Fallas de código	Verificación de certificados TLS desactivada Las conexiones pueden ser interceptadas.	api/app.py:4	—	Quitar esa excepción y corregir el problema del certificado.
18	**Media**	Fallas de código	Modo debug activado Las páginas de debug pueden mostrar código, configuración y secretos a los visitantes.	api/app.py:5	—	Apagar debug fuera del desarrollo local, usando una variable de entorno.

#	Severidad	Área	Problema	Ubicación	Evidencia (enmascarada)	Cómo corregir
19	**Baja**	Configuración de IA	El servidor MCP 'crm' usa un paquete sin versión fija 'npx crm-mcp-server' descarga la versión más reciente cada vez que arranca la herramienta de IA.	.mcp.json	—	Fijar una versión exacta (paquete@1.2.3) y revisar las actualizaciones antes de cambiarla.
20	**Baja**	Dependencias	Sin archivo de bloqueo (lockfile) para dependencias de JavaScript Sin lockfile, cada instalación puede traer versiones distintas, incluso comprometidas.	package.json	—	Subir package-lock.json, yarn.lock o pnpm-lock.yaml.

4. Corregido durante la auditoría

A completar por el auditor: llaves rotadas, accesos públicos cerrados, cuentas eliminadas.

5. Protecciones a instalar

- Bloqueo de secretos antes de cada commit (hook de Gitleaks) y protección de push en GitHub.
- Un archivo de reglas para las herramientas de IA (CLAUDE.md, .cursor/rules, AGENTS.md) con lo que la IA nunca debe hacer: escribir llaves en el código, desactivar controles de seguridad, quitar la seguridad por fila de la base de datos, agregar paquetes desconocidos.
- Revisión obligatoria por una segunda persona antes de publicar, con este escáner en cada pull request.
- Cuentas de empresa (no personales) para cada herramienta de IA, sin entrenamiento con datos de la empresa.
- Secretos guardados en un gestor de secretos o en la configuración del hosting, nunca en archivos.

6. Reglas para desarrollar con IA

1. Solo herramientas de IA aprobadas, con cuentas de la empresa.
2. Nunca pegar contraseñas, llaves, datos de clientes ni contratos en chats de IA.
3. Toda app o automatización que toque datos de clientes, pagos o accesos se registra y se revisa antes de usarse.
4. Nada construido con IA se publica sin revisión de una segunda persona.
5. Reportar de inmediato cualquier llave filtrada; rotarla rápido importa más que buscar culpables.

7. Seguimiento

Nuevo escaneo en 30 días para confirmar correcciones y revisar proyectos nuevos.

Cómo se hizo esta revisión

tienda-en-linea

- git history: scanned, 1 secrets found only in past commits
- built-in checks: secrets, personal data, AI tool settings, database rules, common code flaws
- online checks: skipped (run with --online to verify package names, known-vulnerable libraries and repository visibility)

Conexiones a internet

Su código no se envió a ningún lado. Estas son todas las conexiones que hizo la revisión:

- Ninguna.

Las revisiones automáticas encuentran problemas comunes y conocidos; no prueban que un sistema sea seguro. Los hallazgos deben confirmarse por una persona antes de actuar. Este reporte no incluye valores de secretos.